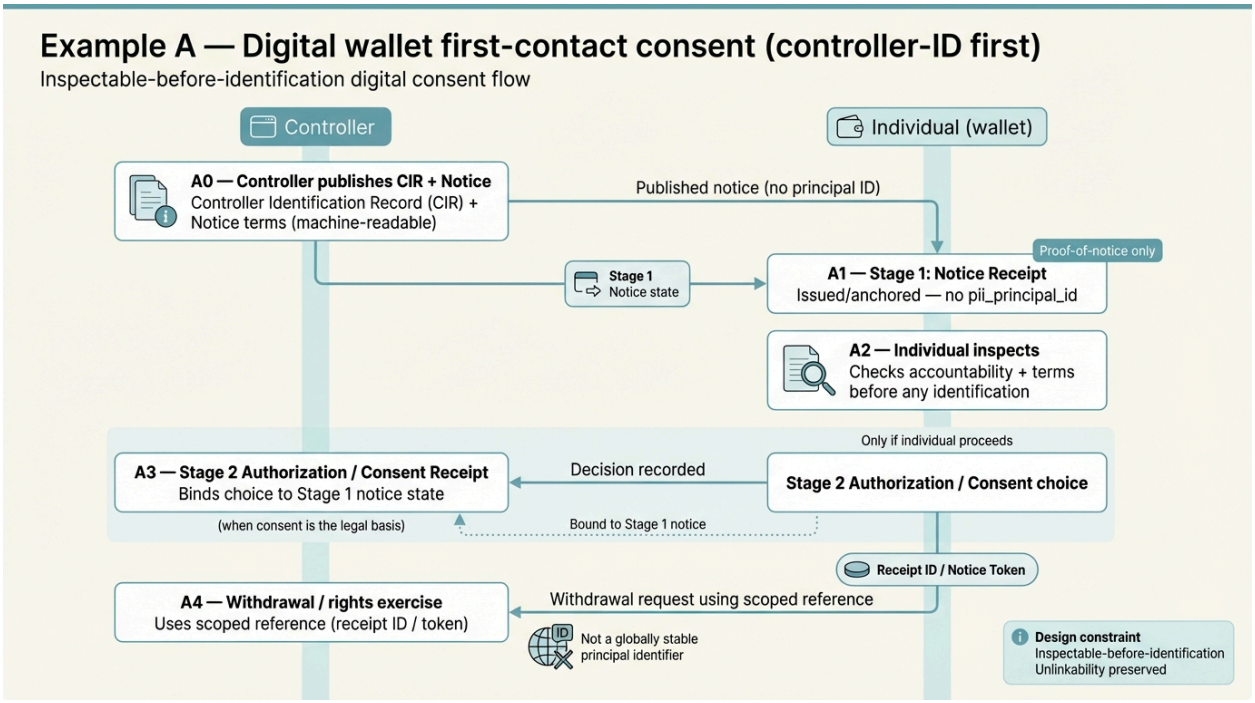
Annex A — Evidence-grade ANCR 27560 - use cases (Digital ID, Age assurance, AI, Digital twin ecosystems) v1

WG5 use case examples

Example A: digital wallet first-contact consent (controller-ID first)

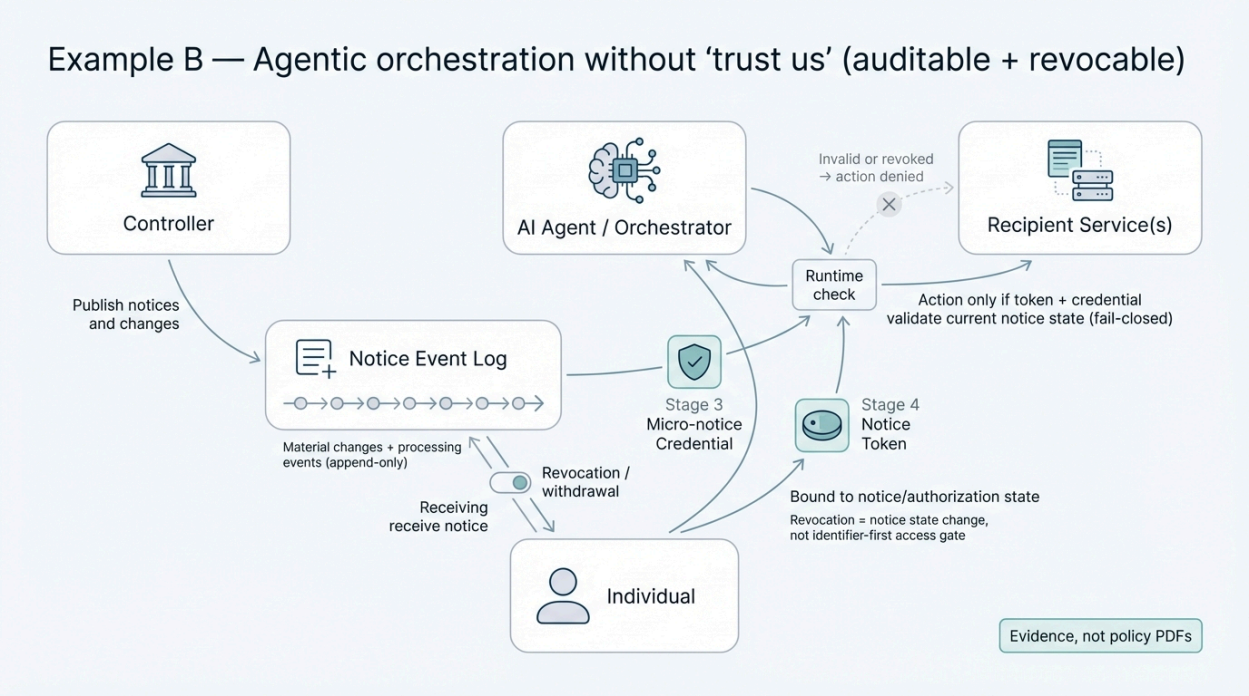


Goal: allow an individual to inspect controller accountability and notice terms before any identification is demanded.

- Controller publishes a Controller Identification Record and Notice terms

- Stage 1 Notice Receipt is issued/anchored (no `pii_principal_id`)
- Only if the individual chooses to proceed does Stage 2 bind authorization/consent (when consent is the legal basis)
- Withdrawal uses a scoped reference (receipt ID / token) — not a globally stable principal identifier

Example B: agentic orchestration without “trust us” (ISO/IEC 27091 alignment)



Goal: make AI-enabled processing and transfers auditable and revocable using evidence, not policy PDFs.

- Notice Event Log records material changes and processing-relevant events
- Micro-notice credentials / Notice Tokens allow runtime verification of permitted actions
- Revocation/withdrawal is represented as a state change bound to the notice/authorization state, not as an identifier-first access gate

Review against ISO/IEC DIS 27091 (alignment notes, draft)

27091 theme (high level)	What ANCR already supports	Gap / strengthening recommendation
Lifecycle privacy risk management	Notice Event Log + staged artefacts represent privacy-impacting changes and decisions over time.	Add an explicit “AI lifecycle checkpoint” mapping (collection → training → deployment → monitoring → change management → decommissioning), each producing/updating a notice state.
Transparency of AI processing + consequences	Machine-readable notice state can enumerate model purpose, decision type, and disclosure scope.	Add a minimal AI transparency payload: model/function category, inference outputs, affected decisions, downstream recipients.
Data minimisation + purpose limitation	Inspectable-before-identification sequencing + scoped references reduce unnecessary identifier binding.	Require scoped token references for rights/withdrawal; avoid routable identifiers.
Rights enablement	Portable receipts/tokens provide a non-identifier-first rights access mechanism.	Add a concrete token-based objection/withdrawal workflow that propagates to model-serving and downstream processors.
Third-party disclosure + cross-border risk	Scope-of-disclosure classification + governance evidence scales requirements with risk.	Require explicit recipient classes (including model vendors/tool providers) and proof-of-authority at higher scopes.

Example C: age assurance / age-restricted access (ISO/IEC 27566-2 aligned)

Goal: How to see what Age Assurance can be trusted? The goal is to provide age-appropriate access controls without converting “age checks” into mass cross-border digital identifier-first surveillance.

Scope of disclosure prevents platform age assurance solutions that result in mass surveillance.

Stage 1 — CIR-first Notice Receipt (no login by default)

- Disclose controller identity + jurisdiction (CIR), age assurance purpose, retention, recipient classes, and dispute/appeal channel.
- Disclose the **age assurance method class**, for example:
  - Attribute-based proof (credential / cryptographic attestation)
  - Document-based verification
  - Biometric estimation / inference
  - Vouching / parental attestation

Stage 2 — Authorization/Consent Receipt (only when consent is the lawful basis)

- If consent is required, bind the decision to the Stage 1 notice state.
- Otherwise, record the asserted legal basis explicitly.

Stage 3 — Micro-credential for access (minimisation rule)

- Present an age proof as an **age-range token** (e.g., “16+”) or minimal attribute assertion.
- Default rule: do not embed stable account identifiers in the token.

Stage 4 — Token + Notice Event Log for expiry, revocation, and redress

- Represent expiry/revocation as a state change bound to the notice/authorization state.`
- Ensure withdrawal/objection (where applicable) and redress are actionable without forcing identifier-first account binding.

Hard constraint: the individual must be able to obtain Stage 1 disclosure and perform baseline age assurance without providing a stable principal identifier.

Conformance test signals (pass/fail examples):

- Pass: Stage 1 notice/CIR is accessible without login/account creation.
- Pass: credential is age-range only (no embedded account ID / correlation handle by default).
- Pass: revocation/expiry/complaint can be initiated using a scoped receipt/token reference (not a global principal ID).

Annex D — Evidence-grade use cases

Example D: ISO/IEC 27568 digital twin ecosystem — consent governance without centralised identity correlation (draft)

Goal: show how ANCR (CIR-first + Notice Receipt + event log + scoped tokens) mitigates *emergent privacy risk* in a system-of-systems digital twin ecosystem, consistent with ISO/IEC 27568’s emphasis on shared risk, ecosystem analysis, and lifecycle controls.

Ecosystem (systems of interest):

- Personal health digital twin (individual-controlled)
- Clinic care coordination digital twin (clinic-controlled)
- Pharmacy medication management digital twin (pharmacy-controlled)

- Optional downstream: analytics / insurer / public health reporting twin (higher scope of disclosure)

Stakeholders & assets:

- Individual (PII principal): autonomy, safety, non-linkability across contexts, ability to revoke/complain
- Clinic/pharmacy operators (controllers): lawful processing evidence, auditability, operational continuity
- Regulators/auditors: comparable evidence of notice-first sequencing + withdrawal effectiveness

Key privacy risks in 27568 terms (ecosystem / emergent risk):

- Cross-twin correlation: a stable identifier shared across twins becomes a linkability rail
- Silent onward disclosure: recipients expand over time without an externally verifiable notice state
- Rights friction: withdrawal/objection requires account binding across each twin operator

ANCR profile controls mapped to the digital twin lifecycle:

1. **Controller Identification Record (CIR-first):** each twin operator publishes verifiable controller identity and jurisdiction prior to any data exchange.
2. **Stage 1 Notice Receipt (before identification):** individual can obtain a portable proof-of-notice for the specific twin purpose and disclosed recipient classes.
3. **Stage 2 Authorization/Consent Receipt (when consent applies):** binds the decision to the Stage 1 notice state (prevents post-hoc rewriting).
4. **Notice Event Log:** material changes (new recipients, new purposes, retention changes) are published as an inspectable state history.
5. **Scoped consent token for cross-twin data flow:** clinic→pharmacy sharing uses a scoped token (purpose-bound, time-bound) rather than broadcasting a stable principal identifier.
6. **Withdrawal/objection propagation:** revocation is represented as a state change tied to the token/receipt reference; downstream twins can fail-closed

without needing a global principal ID.

Conformance test signals (pass/fail examples):

- Pass: each twin operator's CIR is accessible without login and matches the serving domain.
- Pass: the individual can obtain Stage 1 notice evidence before account creation.
- Pass: cross-twin sharing is authorised via a scoped token/reference (not a stable identifier in routable metadata).
- Pass: material changes appear in an event log and are referenceable from receipts.
- Pass: withdrawal can be initiated using a scoped receipt/token reference and results in a verifiable state change.

Why this matters for WG5: this demonstrates that the ANCR 27560-1 profile is not "just consent UI"; it is a reusable, evidence-grade control pattern for multi-controller ecosystems (digital twin systems, digital ID, age assurance, and AI-orchestrated processing).